



MASTG

Insecure Random API Usage

MASTG-TEST-0205: Non-random Sources Usage

MASTG-TEST-0208: Insufficient Key Sizes

MASTG-TEST-0212: Use of Hardcoded Cryptographic Keys in Code

MASTG-TEST-0221: Broken Symmetric Encryption Algorithms

MASTG-TEST-0232: Broken Symmetric Encryption Modes

MASTG-TEST-0307: References to Asymmetric Key Pairs Used For Multiple Purposes

MASTG-TEST-0308: Runtime Use of

L1L2ANDROIDMASWE-0020TEST



MASTG-TEST-0221: Broken Symmetric Encryption Algorithms

Overview

To test for the [use of broken encryption algorithms](#) in Android apps, we need to focus on methods from cryptographic frameworks and libraries that are used to perform encryption and decryption operations.

- `Cipher.getInstance`: Initializes a Cipher object for encryption or decryption. The `algorithm` parameter can be one of the [supported algorithms](#).
- `SecretKeyFactory.getInstance`: Returns a SecretKeyFactory object that converts keys into key specifications and vice versa. The `algorithm` parameter can be one of the [supported algorithms](#).
- `KeyGenerator.getInstance`: Returns a `KeyGenerator` object that generates secret keys for symmetric algorithms. The `algorithm` parameter can be one of the [supported algorithms](#).

Some broken symmetric encryption algorithms include:

- DES (Data Encryption Standard)**: 56-bit key, breakable, [withdrawn by NIST in 2005](#).
- 3DES (Triple DES, officially the Triple Data Encryption Algorithm (TDEA or Triple DEA))**: 64-bit block size, [vulnerable to Sweet32 birthday attacks](#), [withdrawn by NIST on January 1, 2024](#).
- RC4**: Predictable key stream, allows plaintext recovery [RC4 Weakness](#), disapproved by [NIST](#) in 2014 and prohibited by [IETF](#) in 2015.
- Blowfish**: 64-bit block size, [vulnerable to Sweet32 attacks](#), never FIPS-approved, and listed under "Non-Approved algorithms" in FIPS.

Android also provides additional guidance on [broken cryptographic algorithms](#).

Steps

- Run [Static Analysis on Android](#) with a tool such as [semgrep](#) on the app binary, or use [Method Tracing](#) (dynamic analysis) with a tool like [Frida \(Android\)](#), and look for uses of the cryptographic functions that perform encryption and decryption operations.

Observation

The output should contain a list of locations where insecure symmetric encryption algorithms are used.

Evaluation

The test case fails if you can find [insecure or deprecated](#) encryption algorithms being used.

Best Practices

MASTG-BEST-0009: Use Secure Encryption Algorithms

Demos

MASTG-DEMO-0022: Uses of Broken Symmetric Encryption Algorithms in Cipher with semgrep